

Information Security & Access Control Policy



Access Control



Protection



Authentication

1. Purpose

This policy establishes security governance standards to protect enterprise systems, customer data, operational platforms, and regulatory information assets. It defines how access is granted, monitored, reviewed, and revoked.

2. Scope

This policy applies to:

- Employees
- Contractors
- Third-party vendors
- Managed service providers
- All information systems (cloud and on-premises)

3. Role-Based Access Control (RBAC)

Access to systems must follow the principle of **Least Privilege** and **Need-to-Know**.

3.1 RBAC Matrix

Role	Customer Data	Financial Systems	Vendor Portal	Admin Settings	Audit Logs
Customer Support	Read (Masked)	No Access	Read	No	No
Compliance Officer	Read	Read	Read	No	Read
Finance Manager	Read	Read/Write	No	No	Read
IT Administrator	Read	Read	Read	Full	Read
Security Auditor	Read	Read	Read	No	Read (Full)
Vendor User	Limited	No	Limited	No	No

All access rights must be centrally logged and auditable.

4. Access Provisioning Lifecycle

Access must follow a formal lifecycle process.



4.1 Access Provisioning Lifecycle Table

Stage	Description	Owner	Control Requirement
Request	User submits access request	Employee / Manager	Ticket ID required
Approval	Manager & System Owner approval	Manager	Dual approval for sensitive roles
Provisioning	IT creates account & assigns role	IT Admin	MFA mandatory
Verification	Access confirmation by requester	User	Logged confirmation
Periodic Review	Quarterly access certification	Compliance	Revoke unused access
Modification	Role change upon transfer	HR + IT	Triggered automatically
Deprovisioning	Account disabled upon exit	HR + IT	Within 24 hours

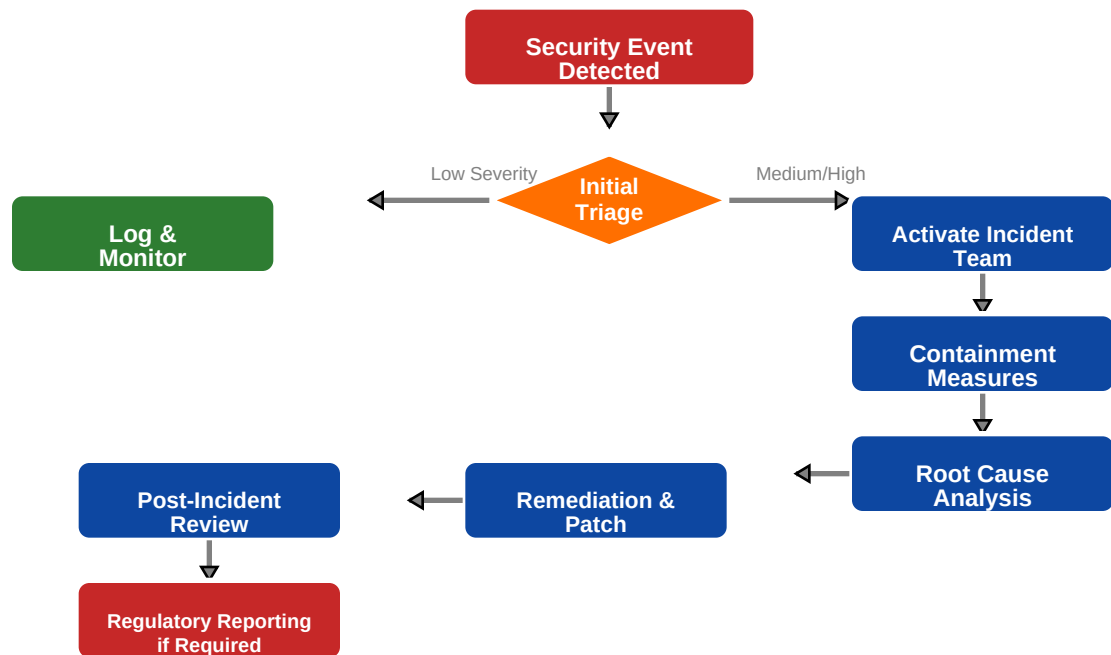
5. Authentication & Security Controls

- Multi-Factor Authentication (MFA) required for all privileged roles.
- Privileged Access Management (PAM) required for administrative accounts.
- Password rotation policy: 90 days.
- Session timeout: 15 minutes inactivity.
- Encryption required for data in transit and at rest.

6. Incident Response Workflow

Security incidents must be managed in a structured, auditable manner.

6.1 Incident Response Flow



7. Security Control Mapping

Security controls must align with recognized frameworks.

7.1 Control Mapping Table

Control Area	Internal Control	ISO 27001 Reference	NIST CSF Category
Access Control	RBAC enforcement	A.9 Access Control	PR.AC
Authentication	MFA requirement	A.9.4.2	PR.AC
Logging & Monitoring	Centralized logs	A.12.4	DE.CM
Incident Response	IR playbooks	A.16	RS
Data Encryption	TLS & AES encryption	A.10	PR.DS
Vendor Access	Third-party access controls	A.15	ID.SC

8. Monitoring & Audit

All privileged activity must be logged.

- Logs retained for minimum 1 year.
- Quarterly access certification required.
- Annual independent security audit.

9. Escalation Protocol

Incidents classified as:

Severity	Definition	Response
Severity 1	Data breach / regulatory exposure	Immediate executive escalation
Severity 2	System compromise	Security team response within 1 hour
Severity 3	Policy violation	Managed within 24 hours

10. Enforcement

Violations may result in:

- Access suspension
- Disciplinary action
- Contract termination
- Legal reporting

11. Policy Review

This policy is reviewed annually by:

- Chief Information Security Officer
- Compliance Committee
- Internal Audit

Disclaimer: This policy defines governance standards for secure access management and does not override applicable regulatory requirements.